ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Microsoft Windows 11 (Enterprise/IoT Enterprise) · Component type: **Host Device (HDR) - workstation/EWS/OWS** · Target SL = SL 3

Where to work	**Local Security Policy** (`secpol.msc`) / **Group Policy** (`gpedit.msc`, domain GPO); **PowerShell** (`Get-*`); Settings; Event Viewer; `auditpol`; `secedit`. Baseline against the **DISA Windows 11 STIG** / **CIS Benchmark**.
Interfaces / ports	RDP **3389** (NLA); SMB **445** (signed, no v1); WinRM **5985/5986**; LDAP(S) if domain; NetBIOS 137-139 (disable). Manage via console / RDP / WinRM.
Notes	HDR (host device). Confirm build (`winver`) and domain/Azure-AD join. Many controls apply via GPO/Intune; verify effective settings with `gpresult /h` / `rsop.msc`.
How to read	Default read-only (read the effective policy / `Get-*` state). Native how-to + external-tool validation + pass. Scan/exploit tools = **authorized**; write/exploit = isolated env.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A;	Confirm interactive logon requires credentials: Guest disabled (`net user guest`), no autologon (`reg query "HKLM\...\Winlogon" /v AutoAdminLogon`), Ctrl+Alt+Del required, cached-creds limited. Domain/Azure-AD SSO where used. **Test:** no anonymous/blank-password logon; Guest cannot log on. **Ext. tools:** SCC/CIS-CAT (STIG scan); `net user` / `whoami /groups`; Nmap (auth services).	All logon requires authentication; Guest disabled; no autologon/blank passwords.	HDR.
SR/CR 1.2	Software Process and Device Identification and Authentication	Assess per objective: Identify and authenticate all software processes and devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.3	Account management	Review local accounts/groups (`net localgroup administrators`); use **Windows LAPS** for the local admin password; remove extra admins; disable stale accounts. **Ext. tools:** PowerShell (`Get-LocalUser`); AccessChk; STIG scan.	Named, least-priv accounts; LAPS-managed local admin; no stale/shared accounts.	
SR/CR 1.4	Identifier Management	Confirm identifiers (user and device IDs) are unique, not reused, and managed over their lifecycle.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.5 / 1.7	Authenticator & password strength	`secpol.msc` › Account Policies › **Password Policy**: min length >=14, complexity ON, history 24, max age; Windows Hello for Business where used. Export/verify with `secedit /export /cfg out.inf`. **Ext. tools:** STIG/CIS scan; `net accounts`	Strong password policy enforced (length/complexity/history/age).	
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.8	Public Key Infrastructure (PKI) Certificates	Confirm any device/server certificates are CA-issued, valid, and revocable per PKI practice.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.9	Strength of Public Key Authentication	Confirm public-key / certificate authentication uses strong keys and algorithms (>=2048 RSA / ECC).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.10	Authenticator Feedback	Confirm authenticators (passwords) are obscured during entry (masked) on every interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.11	Unsuccessful login attempts	Account Policies › **Account Lockout Policy**: threshold (<=10, e.g. 3-5), duration, reset counter; verify with `net accounts`. **Ext. tools:** STIG scan; `net accounts` review.	Lockout after few failed attempts for a set duration.	
SR/CR 1.12	System use notification	Local Policies › Security Options: **Interactive logon: Message text/title for users attempting to log on** set to the approved banner. Confirm it displays at logon. **Ext. tools:** STIG scan; visual check at logon.	Approved legal/use banner displayed before logon.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.13	Access via untrusted networks	RDP with **NLA** + MFA; restrict via Windows Firewall to mgmt subnets; disable SMBv1/NTLMv1; require VPN. **Test:** RDP from untrusted -> blocked/needs MFA. **Ext. tools:** Nmap (3389/445 reachability by segment); firewall rule review.	Remote access requires NLA+MFA and is restricted to mgmt networks.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	Least privilege: **UAC** Admin Approval Mode ON, standard users not admins; **AppLocker / WDAC** allow-list; User Rights Assignment reviewed (`secpol.msc` › Local Policies › User Rights). **Test:** standard user cannot install/run disallowed apps. **Ext. tools:** AccessChk (privileges); `Get-AppLockerPolicy -Effective`; STIG scan.	Least privilege enforced; UAC on; app allow-listing active.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use Control for Portable and Mobile Devices	Assess per objective: Enforce configurable usage restrictions for portable/mobile devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.4	Mobile Code	Assess per objective: Enforce usage restrictions for mobile code technologies.	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 2.4	Mobile Code (Host)	Assess the HDR-specific requirement per objective: Host device shall control and restrict the use of mobile code, enforcing authorization, integrity, and execution constraints.	Met per SL-3 - verify and capture evidence.	HDR completeness
SR/CR 2.5	Session lock	Security Options: **Interactive logon: Machine inactivity limit** (e.g. 900s) + screen-saver lock via GPO. Verify effective policy. **Ext. tools:** STIG scan; `gpresult /h`	Session locks after inactivity.	
SR/CR 2.6	Remote Session Termination	Confirm remote sessions can be terminated on demand and on inactivity timeout.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.7	Concurrent Session Control	Confirm concurrent-session limits or monitoring for privileged/engineering access.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.8	Auditable events	Enable **Advanced Audit Policy** (Logon/Logoff, Account Logon, Object Access, Privilege Use, Policy Change, System) — verify `auditpol /get /category:*`; set Event Log sizes; forward via **WEF** to the SIEM. **Test:** a logon/priv-use event is recorded. **Ext. tools:** auditpol; Event Viewer; SIEM/WEF check.	Security-relevant events audited with user + time; forwarded to SIEM.	
SR/CR 2.9	Audit Storage Capacity	Confirm audit/log storage is sized and rotated and alerts before overflow (or offloads to syslog/SIEM).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.10	Response to Audit Processing Failures	Confirm defined behavior on audit/log processing failure (alert; do not silently drop events).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.11	Timestamps	Time sync: `w32tm /query /status` + `w32tm /query /configuration` to an authenticated NTP/domain source; logs use synced time. **Ext. tools:** `w32tm /query /status`; Wireshark (NTP).	Accurate synchronized time; consistent log timestamps.	
SR/CR 2.12	Non-repudiation	Assess per objective: Determine whether a given human user took a particular action.	Met per SL-3 - verify on the product and capture evidence.	completeness

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
HDR 2.13 / 3.11	Physical / diagnostic interfaces & tamper	Control removable media / USB (GPO Removable Storage Access; Defender device control); BitLocker + TPM protect at rest; locked chassis; disable boot from USB in UEFI (password-protected UEFI). **Ext. tools:** STIG scan; `manage-bde -status`; physical inspection.	USB/boot controlled; UEFI password set; disk encrypted; chassis controlled.	HDR-specific.
SR/CR 3.1 / 3.8	Communication & session integrity	Require **SMB signing** (Microsoft network client/server: Digitally sign communications = Enabled), **LDAP signing**, disable **SMBv1** (`Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`) and NTLMv1; RDP NLA. **Ext. tools:** STIG scan; Nmap smb2-security-mode; Wireshark.	SMB/LDAP signing on; SMBv1/NTLMv1 disabled; sessions integrity-protected.	
SR/CR 3.2 (+ HDR 3.2)	Protection from malicious code	**Microsoft Defender AV** + **ASR rules** + **Tamper Protection** + SmartScreen + Controlled Folder Access; verify `Get-MpComputerStatus` (RealTimeProtectionEnabled, AMServiceEnabled) and `Get-MpPreference` (ASR). WDAC/AppLocker allow-list. **Ext. tools:** `Get-MpComputerStatus`; STIG scan.	AV/ASR/tamper-protection on and current; execution allow-listed.	HDR-specific.
SR/CR 3.3	Security Functionality Verification	Verify security functions operate correctly (self-test / post-change re-verification / compliance scan).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.4 (+ HDR 3.14)	Software integrity & secure boot	**UEFI Secure Boot** (`Confirm-SecureBootUEFI`), **HVCI / Memory Integrity** and WDAC code integrity, signed drivers; **TPM 2.0** present (`Get-Tpm`). **Ext. tools:** `Confirm-SecureBootUEFI`; `Get-Tpm`; STIG scan.	Secure Boot + HVCI + TPM enforce boot/software integrity; only signed code runs.	HDR-specific.
SR/CR 3.5	Input Validation	Assess per objective: Validate syntax and content of any process control input.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error Handling	Confirm errors are handled gracefully without leaking sensitive information or losing control.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.9	Protection of Audit Information	Confirm audit records are protected from unauthorized read/modify/delete (permissions + offload).	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 3.10	Support for updates	Patching via Windows Update / **WSUS** / Intune; verify current (`Get-HotFix`, build/patch level) and a rollback path. **Ext. tools:** `Get-HotFix`; WSUS/Intune compliance.	Signed OS/app updates applied promptly; rollback available.	HDR-specific.
HDR 3.11	Physical Tamper Resistance/Detection (Host)	Assess the HDR-specific requirement per objective: Host device shall resist and/or detect physical tampering.	Met per SL-3 - verify and capture evidence.	HDR completeness
HDR 3.12	Provisioning Supplier Roots of Trust (Host)	Assess the HDR-specific requirement per objective: Host device shall provision and protect product-supplier roots of trust used to validate firmware/identity.	Met per SL-3 - verify and capture evidence.	HDR completeness
HDR 3.13	Secure Boot (Host)	Assess the HDR-specific requirement per objective: Host device shall validate integrity of boot process.	Met per SL-3 - verify and capture evidence.	HDR completeness

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	**BitLocker** full-disk (TPM+PIN where required): `manage-bde -status`; TLS in transit; EFS/DPAPI for sensitive files. **Ext. tools:** `manage-bde -status`; STIG scan.	Data-at-rest encrypted (BitLocker) and in-transit (TLS).	
SR/CR 4.2	Information Persistence	Confirm sensitive data can be purged/sanitized on decommission or re-use.	Met per SL-3 - verify on the product and capture evidence.	completeness

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.3	Use of cryptography	Disable TLS 1.0/1.1 and weak ciphers (Schannel registry / GPO); verify `Get-TlsCipherSuite`; FIPS mode where mandated. **Ext. tools:** sslscan (host services); `Get-TlsCipherSuite`; STIG scan.	TLS 1.2/1.3 + strong ciphers; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1 / 5.2	Segmentation & boundary (host firewall)	**Windows Defender Firewall** ON for all profiles with default-deny inbound + explicit rules: `Get-NetFirewallProfile` / `Get-NetFirewallRule`; block unneeeded inbound; consider IPsec host isolation. **Ext. tools:** Nmap (open inbound ports by segment); `Get-NetFirewallProfile`	Host firewall default-deny inbound; only required flows; profiles enabled.	
SR/CR 5.3	General Purpose Person-to-Person Communication Restrictions	Assess per objective: Prevent general purpose messages from external users/systems.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 5.4	Application Partitioning	Assess per objective: Support partitioning of data, applications, services by criticality.	Met per SL-3 - verify on the product and capture evidence.	completeness

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1 / 6.2	Audit accessibility & monitoring	Logs accessible in Event Viewer / `wevtutil`; forward via **WEF** + **Sysmon** to the SIEM; **Defender for Endpoint** for EDR telemetry. **Ext. tools:** SIEM/WEF verification; Sysmon config review.	Events accessible and forwarded to SIEM; EDR monitoring active.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1	Denial of Service Protection	Assess per objective: Operate in degraded mode during DoS events.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 7.2	Resource Management	Assess per objective: Limit resource use by security functions to prevent exhaustion.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 7.3 / 7.4	Backup & recovery	System image/state backup + tested restore; System Restore / recovery media; verify backup job success and integrity. **Ext. tools:** Backup console review; test restore (lab).	Recent verified backup; restore/recovery tested.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Config settings baseline	Apply and verify the STIG/CIS security baseline (GPO/Intune); `gpresult /h report.html`; document deviations. **Ext. tools:** SCC/CIS-CAT compliance scan vs baseline.	Host matches the STIG/CIS baseline; deviations documented.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.7	Least functionality	Remove/disable unused features/roles/services (`Get-WindowsOptionalFeature -Online`, `Get-Service`), disable SMBv1, close unused ports, uninstall bloatware. **Ext. tools:** Nmap (open ports); Autoruns; STIG scan.	Only required features/services/ports enabled.	
SR/CR 7.8	Component inventory	Capture OS build, patches, and installed software: `systeminfo`, `Get-HotFix`, `Get-Package`. **Ext. tools:** Inventory/EDR agent; ReadOnlyEnum.	Complete OS/patch/software inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
SCAP: SCC / OpenSCAP / CIS-CAT + STIG Viewer	Baseline compliance (all)	Scan against the **DISA Windows 11 STIG** or **CIS Benchmark**; review findings in STIG Viewer; drives most pass/fail evidence.	Authorized scan account.
PowerShell (Get-*)	Effective state of native controls (most rows)	`Get-MpComputerStatus`, `Confirm-SecureBootUEFI`, `Get-Tpm`, `manage-bde -status`, `Get-NetFirewallProfile`, `auditpol /get /category:*`, `net accounts`.	Read-only queries.
Sysinternals (AccessChk / Autoruns)	Privileges & autostart review (2.1, 7.7)	`accesschk` for rights/ACLs; Autoruns for persistence and unneeded startups.	Read-only.
Nmap	Port/service exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 445,3389,5985,5986,135-139 -T2` ; scan by segment; confirm SMBv1/legacy closed.	Tune timing on production.
sslscan / testssl.sh	TLS strength of host services (4.3)	`sslscan :3389` / host TLS services; confirm strong ciphers, no TLS1.0/1.1.	Read-only.
Wireshark / tcpdump	SMB/LDAP signing, comm integrity (3.1)	Confirm SMB2 signing and no cleartext auth (SPAN/tap).	Passive; SPAN/tap only.
WEF / Sysmon + SIEM	Audit forwarding & monitoring (2.8, 6.x)	Verify security events and Sysmon telemetry arrive at the SIEM; trigger a test event.	Coordinate with SIEM team.
Nessus / OpenVAS	Known-CVE vulnerability scan (3.2, general)	Authenticated scan for missing patches / CVEs; cross-check MSRC advisories.	ISOLATED/authorized.
ReadOnlyEnum	Host/network enumeration (7.8)	Enumerate services/ports/config read-only.	Read-only.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.